1. Recopilación de evidencias

Principios

- Capturar imagen del sistema lo más precisa posible.
- Notas detalladas con fechas/horas (local o UTC).
- Minimizar cambios y agentes externos.
- Priorizar recolección antes que análisis.
- Seguir orden de volatilidad.
- Adaptar el proceso a cada dispositivo.

Orden de volatilidad (de mayor a menor)

1. Registros y caché.
2. Tablas de enrutamiento, ARP, procesos, kernel, memoria.
3. Información temporal del sistema.
4. Disco.
5. Logs del sistema.
6. Configuración física y topología de red.
7. Documentos.

Acciones que deben evitarse

- No apagar el equipo antes de recopilar.
- No confiar en programas del sistema comprometidos.
- No ejecutar programas que alteren fechas/horas de acceso.

Privacidad

- Seguir pautas y autorizaciones de la empresa.
- No entrometerse en datos personales sin justificación.
- Evitar recopilar información irrelevante o confidencial sin indicios claros.

Procedimiento de recolección

- Detallado y sin ambigüedades.
- Transparente y reproducible.
- Pasos:
    1. Identificar sistemas afectados.
    2. Determinar relevancia.
    3. Establecer orden de volatilidad.
    4. Obtener información según orden.
    5. Verificar sincronización del reloj.
    6. Documentar cada acción y personas presentes.

Almacenamiento y cadena de custodia

- Documentar **dónde, cuándo y quién** recolecta y maneja la evidencia.
- Registrar custodia, tiempo y condiciones de almacenamiento.
- Detallar intercambios de custodia (con número de referencia).
- Guardar en dispositivos seguros, con detección de accesos no autorizados.

Herramientas necesarias

- Deben ser externas al sistema afectado.
- Preferir herramientas ligeras y no intrusivas.
- Usar soportes de solo lectura (CD, USB).
- Kit básico:
    - Listado de procesos.
    - Estado del sistema.
    - Copias bit a bit.

Conclusión

- La recolección debe ser **precisa, transparente y legal**.
- El orden de volatilidad asegura no perder datos críticos.
- La cadena de custodia garantiza validez jurídica.
- La privacidad y el uso de herramientas adecuadas son esenciales para preservar la integridad de la evidencia.

https://www.incibe.es/incibe-cert/blog/rfc3227

2. Análisis de evidencias

Objetivos

- Reconstruir qué ocurrió y en qué orden.
- Identificar vector de ataque.
- Determinar alcance y daños.
- Detectar persistencia del atacante.
- Proponer medidas de mejora.

Técnicas

- Memoria volátil: Procesos, malware en RAM, conexiones activas.
- Archivos eliminados: Recuperar documentos y datos borrados.
- Metadatos: Fechas, autores, cambios en archivos.
- Tráfico de red: Intrusiones, C2, ataques DDoS.
- Ingeniería inversa: Analizar malware y ejecutables.
- Móviles: Mensajes, llamadas, GPS, apps.
- Nube: Datos en servicios cloud, actividades de usuario.
- Logs: Reconstruir eventos y accesos sospechosos.
- Malware: Payloads, propagación, comunicaciones externas.
- Obfuscación: Detectar y revertir código oculto.

https://www.campusciberseguridad.com/blog/informatica-forense-herramientas-tecnicas-deber-dominar/

3. Investigación del incidente

Fases

1. Respuesta inmediata al incidente
2. Recolección y preservación de evidencia
3. Identificación de causas raíz
4. Desarrollo de acciones correctivas y preventivas (CAPA)
5. Informes y documentación
6. Revisión y cierre de la investigación

https://safex.cl/las-6-etapas-de-la-investigacion-de-incidentes/

4. Intercambio de información

Con quién

- Proveedores (cloud, hosting, telecomunicaciones).
- CERT/CSIRT, INCIBE.
- Fuerzas de seguridad si hay delito.

Qué se comparte

- Indicadores de compromiso (IoCs).
- Descripción del incidente.
- Medidas tomadas.
- Información anonimizada si es sensible.

5. Medidas de contención

- Aislar máquinas afectadas.
- Bloquear IPs, cuentas o servicios.
- Aumentar la monitorización.
- Cambiar contraseñas comprometidas.
- Aplicar parches urgentes.

6. Fundamentos de una plataforma de Pentesting

Tipos de Pentesting

Según el conocimiento del sistema:

- **Caja Negra:** Sin información previa del sistema. Simula un atacante externo.
- **Caja Blanca:** Conocimiento total del sistema (contraseñas, planos, etc.).
- **Caja Gris:** Conocimiento parcial. Mezcla de caja negra y blanca.

Según el ámbito:

- **Ingeniería Social:** Evalúa la manipulación humana para obtener acceso.
- **Física Perimetral:** Evalúa la seguridad física y de red expuesta.
- **Red Externa:** Pruebas desde fuera de la organización (internet).
- **Red Interna:** Pruebas desde dentro de la red corporativa.

Metodologías Profesionales

Marco	Enfoque principal
MITRE ATT&CK	Tácticas y técnicas reales de atacantes (acceso, persistencia, evasión, exfiltración).
OWASP WSTG	Pruebas de seguridad en aplicaciones web, móviles, APIs, contenedores y cloud.
NIST SP 800-115	Guía oficial para planificar y ejecutar pruebas de seguridad.
OSSTMM	Evaluación completa: red, sistemas, comunicaciones, física, transacciones.
PTES	Estándar estructurado: desde permisos hasta post-explotación y reporte.

ISSAF	Evaluación técnica, operativa, física y humana de sistemas de información.

https://alexperezguerrero.com/fundamentos-teoricos-del-pentesting

Componentes principales

a) Sistema operativo base

Las distribuciones más usadas:

- Kali Linux: Incluye herramientas para escaneo, explotación, análisis web, forense, etc.
- Parrot Security OS: Más ligero, orientado también a privacidad y desarrollo.

Ambas permiten trabajar con cientos de herramientas sin instalarlas manualmente.

b) Plataformas colaborativas

- GitHub / GitLab:
  - Control de versiones.
  - Repositorios de scripts y exploits.
  - Documentación interna.
  - Automatización mediante pipelines.

c) Frameworks de explotación y análisis

- Metasploit Framework: Desarrollo y ejecución de exploits, payloads y post-explotación.
- Burp Suite: Análisis y manipulación de tráfico web.
- OpenVAS / Nessus: Escaneo de vulnerabilidades.
- OWASP ZAP: Alternativa open source para pruebas web.

6. Herramientas recomendadas

Herramienta	Descripción breve	Usos principales
Wireshark	Analizador de tráfico de red muy usado en investigaciones.	Captura de paquetes, detección de intrusiones, seguimiento de comunicaciones.
FTK (Forensic Toolkit)	Potente para procesar grandes volúmenes de datos.	Indexación rápida, análisis de correos, recuperación de archivos, análisis de registros del sistema.
Autopsy / Sleuth Kit	Suite gratuita y de código abierto para análisis forense de sistemas de archivos.	Recuperación de datos, análisis de actividad web, extracción de metadatos.
EnCase	Herramienta reconocida para análisis de discos y almacenamiento.	Recuperación de datos eliminados, análisis de sistemas de archivos, metadatos, actividad maliciosa.
Volatility	Especializada en análisis de memoria RAM.	Análisis de imágenes de memoria, detección de malware, procesos activos, artefactos.
X1 Social Discovery	Orientada a redes sociales y comunicación digital.	Captura y análisis de contenido en redes sociales, preservación de evidencia online.

Cellebrite	Líder en análisis forense de móviles.	Extracción de datos móviles, análisis de apps, recuperación de mensajes, GPS.
XRY	Similar a Cellebrite, especializada en móviles modernos.	Extracción de datos móviles, registros de llamadas, recuperación de archivos, multimedia.
Magnet AXIOM	Avanzada, combina datos de múltiples fuentes (discos, móviles, nube).	Análisis de múltiples dispositivos, recuperación de datos en la nube, informes forenses detallados.

https://www.campusciberseguridad.com/blog/informatica-forense-herramientas-tecnicas-deber-dominar/